

WIRESHARK: ANALISI DEL TRAFFICO HTTP E HTTPS

1. Acquisizione del traffico con tcpdump

Qual è l'uso delle opzioni -s e -w di tcpdump?

L'opzione -s specifica la lunghezza massima dei dati acquisiti per ogni pacchetto. Con -s 0, tcpdump utilizza il valore predefinito di 262144 byte, sufficiente a registrare l'intero pacchetto.

L'opzione -w salva invece i pacchetti grezzi nel file indicato, consentendone la successiva analisi con Wireshark.

```
-s snaplen
--snapshot-length=snaplen
  Snarf snaplen bytes of data from each packet rather than the default of 262144 bytes. Packets truncated because of a limited snapshot are indicated in the output with "[[proto]]", where proto is
  the name of the protocol level at which the truncation has occurred.

  Note that taking larger snapshots both increases the amount of time it takes to process packets and, effectively, decreases the amount of packet buffering. This may cause packets to be lost.
  Note also that taking smaller snapshots will discard data from protocols above the transport layer, which loses information that may be important. NFS and AFS requests and replies, for example,
  are very large, and much of the detail won't be available if a too-short snapshot length is selected.

  If you need to reduce the snapshot size below the default, you should limit snaplen to the smallest number that will capture the protocol information you're interested in. Setting snaplen to 0
  sets it to the default of 262144, for backwards compatibility with recent older versions of tcpdump.
```

1 - Sopra: documentazione di tcpdump relativa all'opzione -s e alla lunghezza dello snapshot.

```
-w file
  Write the raw packets to file rather than parsing and printing them out. They can later be printed with the -r option. Standard output is used if file is '-'.

  This output will be buffered if written to a file or pipe, so a program reading from the file or pipe may not see packets for an arbitrary amount of time after they are received. Use the -U flag
  to cause packets to be written as soon as they are received.

  The MIME type application/vnd.tcpdump.pcap has been registered with IANA for pcap files. The filename extension .pcap appears to be the most commonly used along with .cap and .dmp. Tcpdump itself
  doesn't check the extension when reading capture files and doesn't add an extension when writing them (it uses magic numbers in the file header instead). However, many operating systems and appli-
  cations will use the extension if it is present and adding one (e.g. .pcap) is recommended.

  See pcap-savefile(5) for a description of the file format.
```

2 - Sopra: documentazione di tcpdump relativa all'opzione -w e al salvataggio dei pacchetti in un file.

2. Analisi della cattura HTTP

Nota: è stato utilizzato La scansione dei pacchetti è stata effettuata visitando l'url:
<http://testasp.vulnweb.com>

Quali due informazioni vengono visualizzate?

La richiesta POST mostra *tfUName* = *Admin* e *tfUPass* = *Admin*, corrispondenti al nome utente e alla password inseriti nel modulo. Il campo *Key* identifica il parametro, mentre *Value* ne mostra il valore. Poiché la comunicazione utilizza HTTP, entrambe le credenziali sono visibili in chiaro.

181	09:18:58.845288	10.0.2.15	44.238.29.244	HTTP	691	POST /Login.asp?RetURL=%2FDefault%2Easp HTTP/1.1 (application/x-www-form-urlencoded)
182	09:18:58.847355	44.238.29.244	10.0.2.15	TCP	60	80 - 36734 [ACK] Seq=3376 Ack=1068 Win=65535 Len=0
183	09:18:59.026050	44.238.29.244	10.0.2.15	TCP	1494	80 - 36734 [ACK] Seq=3376 Ack=1068 Win=65535 Len=1440 [TCP PDU reassembled in 185]
184	09:18:59.026059	44.238.29.244	10.0.2.15	TCP	1494	80 - 36734 [ACK] Seq=4816 Ack=1068 Win=65535 Len=1440 [TCP PDU reassembled in 185]
185	09:18:59.026059	44.238.29.244	10.0.2.15	HTTP	570	HTTP/1.1 200 OK (text/html)
186	09:18:59.026117	10.0.2.15	44.238.29.244	TCP	54	36734 - 80 [ACK] Seq=1068 Ack=4816 Win=65535 Len=0
187	09:18:59.026199	10.0.2.15	44.238.29.244	TCP	54	36734 - 80 [ACK] Seq=1068 Ack=6256 Win=65535 Len=0
188	09:18:59.024289	10.0.2.15	44.238.29.244	TCP	54	36734 - 80 [ACK] Seq=1068 Ack=6772 Win=65535 Len=0

Frame 181: 691 bytes on wire (5528 bits), 691 bytes captured (5528 bits)	
Ethernet II, Src: PCSysteMec_2f:87:a7 (08:00:27:2f:87:a7), Dst: 52:54:00:12:35:00 (52:54:00:12:35:00)	
Internet Protocol Version 4, Src: 10.0.2.15, Dst: 44.238.29.244	
Transmission Control Protocol, Src Port: 36734, Dst Port: 80, Seq: 431, Ack: 3376, Len: 637	
Hypertext Transfer Protocol	
HTML Form URL Encoded: application/x-www-form-urlencoded	
Form item: "tfUName" = "Admin"	
Key: tfUName	
Value: Admin	
Form item: "tfUPass" = "Admin"	
Key: tfUPass	
Value: Admin	

3 - Sopra: richiesta POST HTTP; i campi *tfUName* e *tfUPass* mostrano in chiaro le credenziali Admin.

3. Analisi della cattura HTTPS

Cosa noti riguardo all'URL del sito web?

L'URL inizia con *https://*, indicando che il sito utilizza HTTPS. La comunicazione è protetta mediante TLS e viene normalmente trasmessa sulla porta TCP 443.

Cosa ha sostituito la sezione HTTP che era nel file di cattura precedente?

Nella visualizzazione di Wireshark, la sezione *Hypertext Transfer Protocol* della precedente richiesta POST è sostituita dalla sezione *Transport Layer Security*, indicata nelle slide con la precedente denominazione *Secure Sockets Layer*. Il contenuto HTTP è cifrato all'interno della connessione TLS e viene mostrato come *Application Data*.

No.	Time	Source	Destination	Protocol	Length	Info
12	09:40:21.632289	10.0.2.15	100.138.192.89	TLSv1.2	239	Application Data
13	09:40:21.632778	100.138.192.89	10.0.2.15	TCP	60	443 → 55178 [ACK] Seq=1 Ack=186 Win=65535 Len=0
14	09:40:21.641972	100.138.192.89	10.0.2.15	TCP	1494	443 → 55178 [ACK] Seq=1 Ack=186 Win=65535 Len=1440 [TCP PDU reassembled in 18]
15	09:40:21.641972	100.138.192.89	10.0.2.15	TCP	1494	443 → 55178 [ACK] Seq=1441 Ack=186 Win=65535 Len=1440 [TCP PDU reassembled in 18]
16	09:40:21.641972	100.138.192.89	10.0.2.15	TCP	1494	443 → 55178 [PSH, ACK] Seq=2881 Ack=186 Win=65535 Len=1440 [TCP PDU reassembled in 18]
17	09:40:21.648289	10.0.2.15	100.138.192.89	TCP	54	55178 → 443 [ACK] Seq=186 Ack=4321 Win=65535 Len=0
18	09:40:21.644573	100.138.192.89	10.0.2.15	TLSv1.2	1453	Application Data
29	09:40:21.685721	10.0.2.15	100.138.192.89	TCP	54	55178 → 443 [ACK] Seq=186 Ack=5728 Win=65535 Len=0
30	09:40:21.725289	10.0.2.15	23.50.152.237	TCP	74	32924 → 443 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=3646882767 TSecr=0 WS=128
31	09:40:21.726289	10.0.2.15	23.50.152.237	TCP	74	32938 → 443 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=3646882768 TSecr=0 WS=128
32	09:40:21.732415	23.50.152.237	10.0.2.15	TCP	60	443 → 32924 [SYN, ACK] Seq=0 Ack=1 Win=65535 Len=0 MSS=1460
33	09:40:21.732415	23.50.152.237	10.0.2.15	TCP	60	443 → 32938 [SYN, ACK] Seq=0 Ack=1 Win=65535 Len=0 MSS=1460
34	09:40:21.732438	10.0.2.15	23.50.152.237	TCP	54	32924 → 443 [ACK] Seq=1 Ack=1 Win=64240 Len=0
35	09:40:21.732578	10.0.2.15	23.50.152.237	TCP	54	32938 → 443 [ACK] Seq=1 Ack=1 Win=64240 Len=0

* Frame 12: 239 bytes on wire (1912 bits), 239 bytes captured (1912 bits) on interface 0
 * Ethernet II, Src: PCSysentec_2f:87:a7 (08:00:27:2f:87:a7), Dst: 52:54:00:12:35:00 (52:54:00:12:35:00)
 * Internet Protocol Version 4, Src: 10.0.2.15, Dst: 100.138.192.89
 * Transmission Control Protocol, Src Port: 55178, Dst Port: 443, Seq: 1, Ack: 1, Len: 185
 * Transport Layer Security
 * TLSv1.2 Record Layer: Application Data Protocol: Hypertext Transfer Protocol
 Content Type: Application Data (23)
 Version: TLS 1.2 (0x0303)
 Length: 180
 Encrypted Data (180 bytes)
 (Application Data Protocol: Hypertext Transfer Protocol)

4 - Sopra: pacchetto TLSv1.2 sulla porta 443; il contenuto applicativo è mostrato come *Encrypted Application Data*.

I dati dell'applicazione sono in formato plaintext o leggibile?

No. I dati dell'applicazione sono cifrati tramite TLS e non risultano leggibili in chiaro. Wireshark mostra solamente *Encrypted Application Data*, senza rendere direttamente visibili la richiesta POST, le credenziali o gli altri contenuti trasmessi.

4. Domande di riflessione

Quali sono i vantaggi dell'uso di HTTPS invece di HTTP?

HTTPS protegge la comunicazione mediante TLS, garantendo la riservatezza e l'integrità dei dati trasmessi. Attraverso il certificato digitale consente inoltre di autenticare il server, riducendo il rischio di intercettazione o modifica delle informazioni durante il transito.

Tutti i siti web che usano HTTPS sono considerati affidabili?

No. HTTPS protegge la connessione con il dominio, ma non garantisce che il sito o il suo contenuto siano affidabili. Anche siti malevoli o di phishing possono utilizzare HTTPS e disporre di un certificato valido.